

Security Principles

IEEE Secure Design Principles (2013)

1. Earn or give, but never assume, trust
2. Use an authentication mechanism that cannot be bypassed or tampered with
3. Authorize after you authenticate
4. Strictly separate data and control instructions and never 1. process control instructions received from untrusted sources.
5. Define an approach that ensures all data is explicitly validated
6. Use cryptography correctly
7. Identify Sensitive data and how they should be handled
8. Always consider the users
9. Understand how integrating external components changes your attack surface
10. Be flexible when considering future changes to objects and actors

Salzer & Schroeder (1974)

1. **Economy of mechanism:** Keep the design as simple and small as possible.
2. **Fail-safe defaults:** Base access decisions on permission rather than exclusion.
3. **Complete mediation:** Every access to every object must be checked for authority.
4. **Open design:** The design should not be secret. The mechanisms should not depend on the ignorance of potential attackers, but rather on the possession of specific, and more easily protected, keys or passwords.
5. **Separation of privilege:** Where feasible, a protection mechanism that requires two keys to unlock it is more robust and flexible than one that allows access to the presenter of only a single key.
6. **Least privilege:** Every program and every user of the system should operate using the least set of privileges necessary to complete the job.
7. **Least common mechanism:** Minimize the amount of mechanism common to more than one user and depended on by all users.
8. **Psychological acceptability:** It is essential that the human interface be designed for ease of use, so that users routinely and automatically apply the protection mechanisms correctly.”